

Official Supplier & Third-Party Security Policy for Acme Bank

1. Document Control

REFERENCE	POL-SSP-020	VERSION	1.0
EFFECTIVE	2026-05-02	NEXT REVIEW	2027-05-02
OWNER	Chief Information Security Officer (CISO)	APPROVER	Chief Executive Officer (CEO)
CLASSIFICATION	Internal — Confidential	FRAMEWORK	ISO 27001:2022

2. Purpose

The purpose of this policy is to ensure that all suppliers and third-party service providers adhere to the same information security standards as Acme Bank. This policy demonstrates the organization's commitment to protecting its information assets and maintaining the confidentiality, integrity, and availability of its systems and data. The Board of Directors and the Chief Executive Officer are responsible for approving and overseeing the implementation of this policy.

3. Scope

This policy applies to all employees, contractors, and third-party service providers who access or handle Acme Bank's information assets. It covers all systems, data, and services used by the organization, including cloud services and ICT supply chain management.

4. Roles & Responsibilities

Role	Responsibility
------	----------------

Board of Directors	Provides strategic oversight and approves security strategy
Chief Executive Officer (CEO)	Demonstrates leadership commitment by approving this policy and allocating resources
Chief Information Security Officer (CISO)	Develops, implements, and maintains this policy; reports to Board
Information Security Manager	Coordinates day-to-day implementation and monitors compliance
Department Managers	Ensure staff compliance and complete required training
IT Department	Implements technical controls and security configurations
Human Resources	Manages security in employment lifecycle and training
All Employees	Comply with this policy and report incidents immediately

5. Policy Statements

All statements are mandatory. SHALL and MUST indicate required actions; MUST NOT indicates prohibited actions.

5.1 Supplier Assessment

- All suppliers and third-party service providers SHALL undergo a thorough risk assessment within 1 hour of onboarding.
- The risk assessment SHALL include a review of the supplier's information security policies, procedures, and controls.
- The supplier SHALL provide evidence of compliance with Acme Bank's information security standards within 24 hours of onboarding.
- The supplier SHALL agree to maintain a minimum of 99.9% uptime for all services provided to Acme Bank.

5.2 Security Requirements in Contracts

- All contracts with suppliers and third-party service providers SHALL include a clause requiring compliance with Acme Bank's information security standards.
- The contract SHALL include a provision for regular security audits and reviews.
- The supplier SHALL agree to notify Acme Bank immediately in the event of a security incident or breach.
- The supplier SHALL agree to maintain a minimum of 14 characters for all passwords and authentication credentials.

5.3 Supplier Monitoring

- Acme Bank SHALL monitor all suppliers and third-party service providers for compliance with information security standards on a quarterly basis.
- The monitoring SHALL include a review of the supplier's information security policies, procedures, and controls.
- The supplier SHALL provide regular security reports and updates to Acme Bank.
- The supplier SHALL agree to implement any recommended security controls or measures within 7 days of notification.

5.4 Cloud Service Security

- All cloud services used by Acme Bank SHALL meet the organization's information security standards.
- The cloud service provider SHALL agree to maintain a minimum of 99.9% uptime for all services provided to Acme Bank.
- The cloud service provider SHALL agree to notify Acme Bank immediately in the event of a security incident or breach.
- The cloud service provider SHALL agree to maintain a minimum of 14 characters for all passwords and authentication credentials.

5.5 Supply Chain Security

- Acme Bank SHALL assess the security risks associated with all suppliers and third-party service providers on a quarterly basis.
- The assessment SHALL include a review of the supplier's information security policies, procedures, and controls.
- The supplier SHALL agree to implement any recommended security controls or measures within 7 days of notification.
- The supplier SHALL agree to maintain a minimum of 99.9% uptime for all services provided to Acme Bank.

5.6 Supplier Termination

- Acme Bank SHALL terminate any contract with a supplier or third-party service provider who fails to comply with information security standards.
- The termination SHALL be effective immediately in the event of a security incident or breach.
- The supplier SHALL agree to return all Acme Bank property and data within 24 hours of termination.

- The supplier SHALL agree to maintain confidentiality and not disclose any Acme Bank information to third parties.

Framework Alignment

ISO 27001:2022: This policy addresses ISO 27001:2022 controls: A.5.19 Information security in supplier relationships, A.5.20 Addressing information security within supplier agreements, A.5.21 Managing information security in the ICT supply chain, A.5.22 Monitoring and review of supplier services, A.5.23 Information security for use of cloud services. Each control has been incorporated into the policy statements.

Exceptions

Exceptions MUST be requested in writing, approved by the CISO, documented in the exception register, and reviewed annually. All exceptions expire after 12 months unless renewed.

Enforcement

Violations may result in disciplinary action up to termination. Third parties in violation may have access revoked and contracts terminated.

Definitions

Term	Definition
Confidential	Information requiring protection from unauthorized disclosure.
Information Asset	Any data, system, or service with value to the organization.
Security Incident	An event threatening confidentiality, integrity, or availability.
Third Party	External entities accessing organizational systems or data.
Compliance	Adherence to applicable laws, regulations, and policies.

Related Documents

- Acme Bank ISMS Manual

- Acme Bank Risk Assessment Procedure
- Acme Bank Incident Response Procedure
- Acme Bank Security Awareness Training Program

Revision History

Version	Date	Author	Description
1.0	2026-05-02	AutoAudit AI	Initial release



John A. Smith
Chief Executive Officer (CEO)
Acme Bank

